

16강 강의 대본

보안 관리 — "내 프로젝트 키 노출 점검해줘"

강의 시간	40분 (빠른 템포 발화 기준)
대상	디스플레이·반도체 현장 엔지니어
촬영 구성	교안 화면 녹화 + 강사 캠 PIP
교안 URL	https://heekeunlee.github.io/lecture16/

대본 읽는 법

【지문】→ 카메라·화면 동작, 강사 행동 지시

(괄호 안) → 말투·속도·강조 지시

굵게 → 강조하여 또렷하게 발음

[잠깐] → 1~2초 호흡 멈춤

▶ **AI에게 이렇게 시킵니다** → 학생이 AI에 입력하는 지시문(프롬프트)

AI가 만들어 준 결과 → AI가 자동 생성한 코드/출력 (사람은 검증만)

강의 흐름 요약

시간	교안 섹션	핵심 내용
0:00	헤더 + 00. Learning Goal	인트로 — 30분이 30만원
3:00	01. 실제 노출 피해 사례	Gemini·AWS 두 건
8:00	02. AI에게 보안 점검 시키기	리포 전체를 한 번에
16:00	03. AI에게 .env·gitignore 정비 시키기	안전한 기본값으로
22:00	04. AI에게 GitHub Secrets 워크플로우 시키기	Actions yml 자동
28:00	05. AI에게 Functions 서버사이드 보안 시키기	키는 서버에만
33:00	06. 사고 대응 30분 플레이북	노출되면 무엇부터
37:00	07. Quality Gate & 17강 예고	메시징으로

SECTION 00 · 인트로 & 학습목표 0:00 ~ 3:00 / 3분

교안: 헤더 + 00. Learning Goal

안녕하세요, 16강입니다.

(차분히, 단호) 오늘은 — 가장 따분하지만 — 가장 중요합니다. [잠깐]

(중요) 보안 강의라고 해서 — 여러분이 직접 — 보안 코드를 — 짜진 않습니다. AI에게 — "내 프로젝트 점검해 줘" — 라고 — 시킬 뿐입니다.

"오늘 — 친 한국어 — 5개 지시문이 —
여러분의 — "보안 합격 도장"이 됩니다."

SECTION 01 · 실제 노출 피해 사례 3:00 ~ 8:00 / 5분

교안: 01. Real Breach Cases

Gemini Key 노출(2025.3) — 30분 탐지, \$300 청구.

AWS Key 노출(2024.11) — 12시간 만에 EC2 100대, \$50,000 청구. [잠깐]

스캔 봇은 — 정규식 패턴으로 — GitHub Public 리포를 — 분 단위로 — 훑습니다.

SECTION 02 · AI에게 보안 점검 시키기 8:00 ~ 16:00 / 8분

교안: 02. AI Security Audit

▶ AI에게 보안 감사를 시킵니다

이 프로젝트의 보안을 점검해줘.

확인 항목:

- 1) 코드 본문에 — AlzaSy·sk·AKIA 같은 키 패턴이 — 노출돼 있는지
- 2) .env가 .gitignore에 — 등록돼 있는지
- 3) git history에 — .env 또는 serviceAccountKey.json이 — 커밋된 적 있는지
- 4) hard-coded URL·비밀번호·토큰이 — 있는지

각 항목을 / 로 표시하고, 가 있으면 정확한 파일·라인 번호와 — 즉시 적용 가능한 수정안을 — 제시해줘.

(에너지) 이 한 번의 지시로 — 보안 감사 — 완료됩니다. [잠깐]

(중요) AI가 — "3번 항목 — .env가 — 커밋된 적 있음" — 이라고 — 답한다면 — 그 자체로 — 다음 지시문이 — 떠오릅니다.

▶ 이어 시키기 — 사고 발견 시 즉시 대응

방금 점검에서 .env가 과거 커밋된 사실이 발견됐어. 다음을 즉시 처리해줘.

- 1) 노출 가능성 있는 키들 — 즉시 — 재발급 절차 안내 (Gemini·Firebase)
- 2) git filter-repo로 — 히스토리에서 — .env 완전 삭제하는 명령 시퀀스
- 3) 팀원에게 — re-clone을 요청하는 — 안내 메시지 — 한국어로 작성

SECTION 03 · AI에게 .env·gitignore 정비 시키기 16:00 ~ 22:00 / 6분

교안: 03. Spawn Safe Defaults

▶ AI에게 안전 기본값을 시킵니다

이 프로젝트의 .env, .env.example, .gitignore를 — 보안 표준에 맞춰 정비해줘.

조건:

- 1) .env.example — 키 이름만 있고, 값은 — "YOUR-KEY-HERE" 형식
- 2) .gitignore — .env, *.key, serviceAccountKey.json, .firebase, 가상환경, IDE 설정 포함
- 3) README에 — 신규 팀원이 — .env를 — 설정하는 — 3단계 절차 추가

SECTION 04 · GitHub Secrets 워크플로우 자동화 22:00 ~ 28:00 / 6분

교안: 04. Spawn CI Secrets

▶ AI에게 CI 워크플로우를 시킵니다

GitHub Actions로 — main 푸시 시 — Firebase Hosting에 — 자동 배포되는 워크플로우를 만들어줘.

조건:

- 1) .github/workflows/deploy.yml — pip install → firebase deploy
- 2) GEMINI_API_KEY, FIREBASE_TOKEN은 — secrets에서 주입
- 3) 로그에 — 키가 — 출력되지 않도록 — 마스킹 처리
- 4) README에 — GitHub Secrets 등록 절차 (사람이 누를 단계)를 — 명시

(중요) 사람이 누를 부분은 — "Settings → Secrets → 새 시크릿 등록" — 단 한 페이지. [잠깐]
이름·값을 — 채워 넣는 것만 — 본인이 — 합니다. 그 외에는 — AI가 만든 yml 그대로.

SECTION 05 · AI에게 Functions 서버사이드 보안 시키기 28:00 ~ 33:00 / 5분

교안: 05. Spawn Server-side Guard

▶ AI에게 "키는 서버에만" 구조를 시킵니다

클라이언트(Streamlit/React)에서 — 직접 Gemini를 — 호출하지 않고,
Firebase Functions를 — 거치도록 — 구조를 — 바꿔줘.

조건:

- 1) functions/main.py — Gemini API 호출 함수 ask_gemini(prompt) 1개
- 2) SecretParam('GEMINI_API_KEY') 사용 — 클라이언트는 키를 — 절대 모름
- 3) HTTP 트리거, 인증된 사용자만 호출 가능 (Firebase Auth 토큰 검증)
- 4) 클라이언트 측 호출 예제 (Streamlit) 코드 1개 추가

"클라이언트에 키가 있다는 건 —

"노출까지 — 시간 문제"입니다. — 그래서 — 서버에 둡니다."

SECTION 06 · 사고 대응 30분 플레이북 33:00 ~ 37:00 / 4분

교안: 06. Incident Playbook

분	조치	주체
0~5분	노출 키 — 즉시 재발급/회수	사람
5~10분	리포 Private 전환 또는 삭제	사람
10~20분	비정상 호출량 확인 (Cloud Console)	사람 + AI 요약
20~30분	예산 상한 — 즉시 하향, 알림 ON	사람

분	조치	주체
+24시간	AI에게 — "사고 회고록 초안 작성해 줘" 시키기	AI

(차분) 이 표를 — 휴대폰에 — 저장해 두세요. 새벽 알림 받았을 때 — 바로 — 꺼냅니다. [잠깐]

SECTION 07 · Quality Gate & 17강 예고 37:00 ~ 40:00 / 3분

교안: 07. Quality Gate & Bridge

AI 보안 감사 — 모든 항목이 — 인가?
.env.gitignore — AI가 만든 표준 그대로 — 반영되었는가?
GitHub Secrets — GEMINI_API_KEY·FIREBASE_TOKEN — 둘 다 등록됐는가?
Functions — 서버사이드에서 — 키가 — 정상 동작하는가?
Cloud Console — 예산 알림 \$10/\$25/\$50 — 모두 — 켜져 있는가?

"오늘의 따분함이 — 내일의 평화입니다.
여러분이 — 친 — 한국어 — 5줄이 — 30만 원을 지킵니다."

다음 17강 — Telegram 봇 알림 자동화. 시리즈의 마지막입니다. 16강 수고하셨습니다!

부록 A · 강의 흐름 타임라인

구간	시간	교안 섹션	핵심 멘트
인트로	0:00~3:00	헤더 + 00	"30분이 30만 원."
사례	3:00~8:00	01	"AWS — 12시간에 \$50,000."
AI 감사	8:00~16:00	02	"한 번 시키면 점검 끝."
.env 정비	16:00~22:00	03	"안전 기본값 — AI가."
CI 시크릿	22:00~28:00	04	"등록만 사람 — yml은 AI."
Functions	28:00~33:00	05	"키는 서버에만 — AI 구조 변경."
플레이북	33:00~37:00	06	"30분 안에 끝는다."
마무리	37:00~40:00	07	"한국어 5줄이 — 평화를 만든다."

부록 B · 강사 유의사항

항목	내용
강의 톤	단호하되 무겁지 않게. 사례 끝마다 "우리는 — AI에게 시켜서 — 안 그러게 한다" 가벼운 환기.
AI 검증	AI가 — 키 노출을 — 놓치는 경우도 있음을 — 한 번 명시 (사람 최종 확인 강조).
실습 침묵	AI 보안 감사 응답 5초 — 침묵 + 시청자 시선 유도.
강조 반복	"한국어 5줄이 30만 원" — 본 강의 핵심 슬로건. 3회 반복.
주의	git filter-repo는 위험 — "AI가 만든 명령은 — 사전에 한 번 — 사람이 — 읽고 — 실행" 안내.
에너지	보안 강의가 무거워지지 않도록, 매 섹션 끝에 "AI가 합니다" 한마디로 톤 회복.